Application des notes

Owner: Votre nom
Reviewer: Votre relecteur
Contributors:
Date Generated: Mon Oct 26 2026

Executive Summary

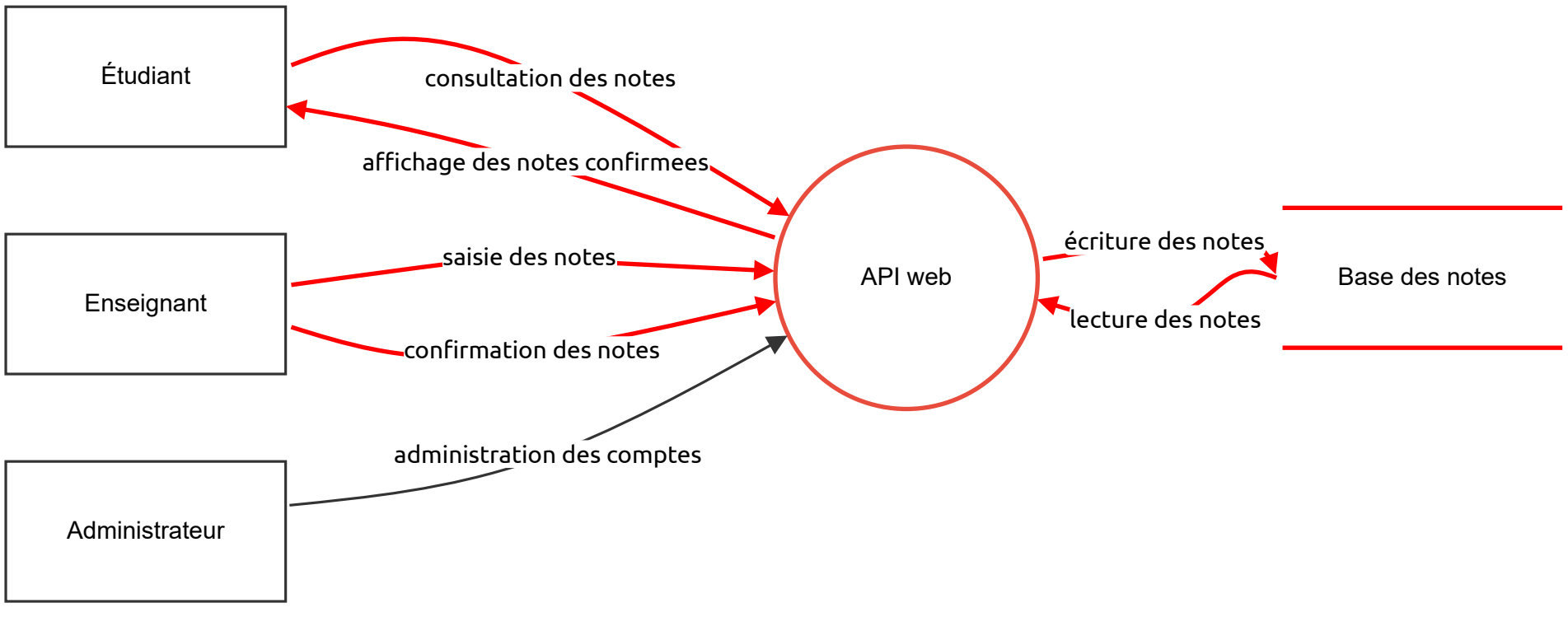
High level system description

Modèle de menaces STRIDE de l'application de gestion des notes.

Summary

Total Threats	20
Total Mitigated	0
Total Open	20
Open / Critical Severity	0
Open / High Severity	11
Open / Medium Severity	8
Open / Low Severity	1

Flux de données



Flux de données

Étudiant (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Enseignant (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Administrateur (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

API web (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	Usurpation d'un enseignant ou d'un administrateur	Spoofing	High	Open		Un attaquant se fait passer pour un enseignant et saisit ou confirme de fausses notes.	Authentification forte, jetons signés (JWT) avec expiration courte.
2	Élévation de privilèges	Elevation of privilege	High	Open		Un étudiant appelle les routes de saisie ou de confirmation réservées aux enseignants.	Contrôle d'accès par rôle (RBAC) sur chaque route, principe du moindre privilège.
3	Déni de responsabilité sur la saisie ou la confirmation	Repudiation	Medium	Open		Un enseignant nie avoir modifié ou confirmé une note, sans preuve possible.	Journalisation horodatée et infalsifiable (qui, quand, ancienne/nouvelle valeur).
4	Saturation de l'API en période de résultats	Denial of service	Medium	Open		Pic de requêtes ou attaque volontaire rendant le service indisponible.	Limitation de débit (rate limiting), cache, répartition de charge, WAF.

Base des notes (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
5	Altération directe des notes en base	Tampering	High	Open		Un accès illégitime à la base (injection SQL, compte compromis) modifie les notes.	Requêtes paramétrées, comptes de base à droits minimaux, sauvegardes et contrôle d'intégrité.
6	Fuite de la base des notes	Information disclosure	High	Open		Vol ou exposition d'une sauvegarde ou de la base contenant les données personnelles des étudiants.	Chiffrement au repos, accès réseau restreint, chiffrement des sauvegardes.
7	Absence de traçabilité des modifications	Repudiation	Medium	Open		Impossible de savoir qui a modifié une note en base.	Journal d'audit en base, historique des versions des notes.

consultation des notes (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
8	Interception des notes en transit	Information disclosure	High	Open		Un attaquant sur le réseau (Wi-Fi public) intercepte la requête de consultation et lit les notes de l'étudiant.	Imposer HTTPS/TLS 1.2+, HSTS, cookies Secure et HttpOnly.
9	Usurpation de l'identité d'un étudiant	Spoofing	High	Open		Vol de session ou d'identifiants : un tiers consulte les notes d'un autre étudiant.	Authentification forte (MFA), sessions à durée limitée, verrouillage après échecs.
10	Modification de la requête (accès aux notes d'autrui)	Tampering	Medium	Open		L'étudiant modifie l'identifiant dans la requête pour lire les notes d'un camarade (IDOR).	Contrôle d'accès côté serveur : un étudiant ne lit que ses propres notes.

affichage des notes confirmees (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
11	Notes affichées avant confirmation	Information disclosure	High	Open		L'étudiant voit une note saisie mais pas encore confirmée par l'enseignant.	Ne renvoyer que les notes au statut « confirmée » (filtre côté serveur).
12	Réponse interceptée ou modifiée en transit	Tampering	Medium	Open		Un attaquant intercepte la réponse et modifie la note affichée.	TLS obligatoire, en-têtes de sécurité, signature des réponses sensibles.

saisie des notes (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
13	Saisie de fausses notes	Tampering	High	Open		Un tiers ou un compte compromis saisit ou modifie des notes.	Authentification forte, validation des entrées, historique des modifications.
14	Saisie par un non-enseignant	Spoofing	High	Open		Un étudiant se fait passer pour un enseignant pour écrire des notes.	Contrôle de rôle sur la route de saisie, MFA pour les enseignants.

confirmation des notes (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
15	Confirmation de notes par un tiers	Tampering	High	Open		Un attaquant rejoue ou falsifie la requête de confirmation et publie des notes non validées.	Jeton anti-CSRF, signature de la requête, ré-authentification avant confirmation.
16	Données de confirmation exposées	Information disclosure	Medium	Open		Les notes saisies transitent sur Internet avant publication.	TLS obligatoire, aucune note dans les URL ni les journaux.

lecture des notes (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
19	Lecture de notes non autorisées	Information disclosure	Medium	Open		Une requête mal filtrée retourne les notes d'autres étudiants à l'API.	Filtrer par identifiant d'étudiant dans la requête, vues SQL restreintes.
20	Écoute du trafic API - base	Information disclosure	Low	Open		Le trafic interne est lu si le réseau serveur est compromis.	Chiffrer la connexion à la base (TLS), segmenter le réseau.

administration des comptes (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

écriture des notes (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
17	Injection SQL lors de l'écriture	Tampering	High	Open		Une entrée malveillante altère la requête d'écriture et modifie d'autres notes.	Requêtes paramétrées, validation stricte des champs, droits minimaux du compte applicatif.
18	Écriture sans trace	Repudiation	Medium	Open		Une note est écrite sans enregistrer l'auteur ni la date.	Journal d'audit : auteur, date, ancienne et nouvelle valeur.